Integrantes: Heidi Villavicencio | Steeven Toala | Nixon Hurtado | Andrea Vásquez

1. TÍTULO

Denominación Oficial del Entregable: Pruebas de Integración y Seguridad (Auditoría OWASP Top 10) – Código EDT: 4.2

2. INTRODUCCIÓN

La seguridad y confidencialidad de la información docente y documental en la Universidad Técnica de Ambato representan un imperativo ético y legal estipulado en la Ley Orgánica de Protección de Datos Personales (LOPDP). Para certificar que el sistema web SIGE es resiliente frente a vulnerabilidades y vectores de ataque modernos, se realizó una auditoría técnica de seguridad y pruebas de penetración (*Pentesting*) en modalidad caja gris (*Gray Box*), evaluando rigurosamente cada una de las 10 categorías de amenazas del estándar OWASP Top 10:2021. El presente informe formaliza las pruebas de estrés de seguridad y las defensas implementadas en el backend y frontend.

3. OBJETIVO

3.1. Objetivo General

Ejecutar la auditoría de seguridad integral y pruebas de penetración basadas en el estándar OWASP Top 10 sobre el sistema SIGE, certificando la ausencia de vulnerabilidades de severidad alta o crítica.

3.2. Objetivos Específicos

- Evaluar la robustez del sistema frente a inyecciones SQL, Cross-Site Scripting (XSS) y fallas de control de acceso.
- Auditar los mecanismos de cifrado, gestión de tokens JWT y firmas criptográficas SHA-256.
- Emitir la matriz formal de mitigación de riesgos de seguridad OWASP.

4. ALCANCE

4.1. Límites del Entregable (In-Scope)

- Evaluación de las 10 categorías OWASP Top 10:2021 sobre la API REST y la SPA en React.
- Pruebas de inyección de parámetros, adulteración de tokens y manipulación de cabeceras HTTP.

4.2. Exclusiones (Out-of-Scope)

- Ataques de denegación de servicio distribuido (DDoS) masivos volumétricos a nivel de ISP.

5. DEFINICIONES

- **OWASP Top 10:** Documento de consenso mundial que clasifica los diez riesgos de seguridad más críticos para las aplicaciones web.
- **Pentesting (Caja Gris):** Prueba de penetración donde el evaluador posee credenciales legítimas y conocimiento parcial de la arquitectura para simular amenazas internas y externas.
- **Broken Access Control (A01):** Falla de seguridad donde los usuarios pueden actuar fuera de sus permisos asignados accediendo a datos no autorizados.

6. RESPONSABILIDADES

- **Steeven Toala (Responsable EDT 4.2):** Auditoría de seguridad técnica, ejecución de pentesting y análisis de código estático (SAST).
- **Nixon Hurtado (Especialista en Seguridad de Datos):** Verificación de políticas en PostgreSQL 18 y MinIO S3.
- **Ing. Paulo Torres (Docente Evaluador):** Aprobación del informe de auditoría de seguridad.

7. NORMATIVA LEGAL Y TÉCNICA

7.1. Marco Legal Ecuatoriano

- **Ley Orgánica de Protección de Datos Personales (LOPDP), Art. 32 y 37:** Deber de seguridad, confidencialidad e integridad del tratamiento automatizado de datos.
- **Código Orgánico Integral Penal (COIP), Arts. 230 a 234:** Delitos contra la seguridad de los activos de los sistemas de información y comunicación.

7.2. Normas Técnicas Internacionales

- **OWASP Top 10:2021 (The Ten Most Critical Web Application Security Risks).**
- **OWASP Application Security Verification Standard (ASVS) v4.0.**
- **ISO/IEC 27001:2022 (Information Security Management).**

8. MÉTODO, POLÍTICAS Y CONTENIDOS

8.1. Enfoque Metodológico

Se aplicó la metodología de pruebas de penetración descrita en el estándar NIST SP 800-115, comprendiendo las fases de Reconocimiento, Análisis de Vulnerabilidades, Explotación Controlada y Reporte. Se utilizaron herramientas automatizadas como OWASP ZAP y análisis de dependencias de seguridad, complementadas con pruebas manuales dirigidas a los endpoints de la API REST para verificar el control de acceso en objetos directos (*BOLA / IDOR*).

8.2. Políticas de Calidad de Seguridad de la Información

1. **Política de Cero Vulnerabilidades Críticas (Zero High/Critical Policy):** Ningún entregable puede pasar a producción con hallazgos abiertos clasificados como High o Critical.
2. **Política de Menor Privilegio (Principle of Least Privilege):** Las conexiones del backend a PostgreSQL utilizan credenciales limitadas exclusivamente al esquema operativo del sistema.
3. **Política de Sanitización Universal:** Todo parámetro de entrada proveniente del cliente es sanitizado y evaluado mediante validadores de esquema antes de alcanzar la capa de base de datos.

9. DESCRIPCIÓN DE ACTIVIDADES

La validación de seguridad de caja gris y las pruebas de integración de extremo a extremo tuvieron como objetivo certificar la resistencia del sistema ante vectores de vulnerabilidad comunes y garantizar la consistencia transaccional de los flujos entre capas. El equipo de control de calidad ejecutó las siguientes actividades técnicas:

- **Diseño y Ejecución de la Suite de Pruebas de Integración con Supertest:** Se automatizaron escenarios de prueba sobre los endpoints de la API REST de Express v5, simulando el ciclo completo del documento desde la autenticación, creación del borrador y persistencia en lote de la matriz, hasta la emisión de firmas y exportación en PDF.
- **Auditoría de Vulnerabilidades Web según el Estándar OWASP Top 10:2021:** Se aplicaron pruebas de penetración sobre la interfaz web y los controladores backend, evaluando la resistencia frente a inyección SQL, control de acceso roto (Broken Access Control), fallas criptográficas y exposición indebida de datos.
- **Simulación de Vectores de Inyección SQL y Tampering de Tokens JWT:** Se verificó que el uso de consultas parametrizadas en `pg-promise` y la firma criptográfica HMAC-SHA256 de los tokens impidan cualquier escalamiento no autorizado de privilegios o alteración del identificador de usuario (`user_id`).

- **Inspección de Cabeceras de Seguridad HTTP y Políticas CORS:** Se configuró e inspeccionó el middleware `helmet`, verificando la aplicación de Content Security Policy (CSP), protección contra ataques de clickjacking (`X-Frame-Options: DENY`) y restricción estricta de orígenes permitidos en llamadas asíncronas.

9.1. Matriz Oficial de Evaluación OWASP Top 10:2021 en SIGE

A continuación se detalla la matriz que documenta la evaluación de seguridad realizada para cada categoría del estándar internacional OWASP:

Ref.	Categoría OWASP	Mecanismo de Mitigación Implementado	Severidad	Resultado
A01	Broken Access Control	Validación RBAC en middleware; bloqueo IDOR con verificación de pertenencia del plan.	Crítica	**MITIGADO**
A02	Cryptographic Failures	Contraseñas con Argon2id; JWT firmado con HMAC-SHA256; TLS en transporte.	Alta	**MITIGADO**
A03	Injection (SQL / XSS)	Consultas parametrizadas con pg-promise; sanitización HTML estricta con DOMPurify.	Crítica	**MITIGADO**
A04	Insecure Design	Validation Gates en backend; transacciones atómicas en cambios de estado de planes.	Alta	**MITIGADO**
A05	Security Misconfiguration	Cabeceras de seguridad Helmet; cookies HttpOnly y SameSite; CORS restrictivo.	Media	**MITIGADO**
A06	Vulnerable Components	Auditoría de dependencias npm audit; contenedores base mínimos con Alpine Linux.	Media	**MITIGADO**
A07	Identification Failures	Bloqueo tras 5 intentos fallidos (15 min); expiración de tokens de acceso en 15 minutos.	Alta	**MITIGADO**
A08	Software Integrity	Hashes SHA-256 en evidencias; URLs prefirmadas MinIO con tiempo de expiración corto.	Alta	**MITIGADO**
A09	Logging Failures	Registro de auditoría centralizado con Winston; rotación periódica y eventos de login.	Baja	**MITIGADO**
A10	Server-Side Request	Endpoints de descarga con lista blanca estricta; sin invocación de URLs externas arbitrarias.	Media	**MITIGADO**

Tabla 1: Matriz oficial de auditoría de seguridad bajo estándar OWASP Top 10:2021.

9.2. Análisis Técnico de Defensas en Profundidad y Control de Acceso

La implementación de la seguridad en el sistema SIGE responde al principio de defensa en profundidad (*Defense in Depth*). Para mitigar la categoría A01 (Broken Access Control), se diseñó un interceptor que extrae el identificador del usuario autenticado a partir del token JWT y comprueba en la base de datos la propiedad del documento antes de ejecutar operaciones de actualización o eliminación. Esto neutraliza de raíz los ataques de referencia directa a objetos inseguros (IDOR), donde un usuario malintencionado intenta manipular expedientes ajenos cambiando el UUID en la URL. Asimismo, la persistencia en cookies con atributos `HttpOnly`, `Secure` y `SameSite=Strict` impide que scripts maliciosos en el cliente puedan acceder a los tokens de sesión.

10. FIRMAS DE RESPONSABILIDAD

ACCIÓN	NOMBRE Y CARGO	FIRMA	FECHA
Elaborado por:	Heidi Villavicencio Analista de Calidad / UI-UX		13/10/2026
Revisado por:	Steeven Toala Líder de Proyecto / Arquitecto		13/10/2026
Aprobado por:	Ing. Paulo Torres, Mg. Docente Evaluador – Gestión Proyectos	[PENDIENTE DE APROBACIÓN]	**Pendiente**

11. CONTROL DE CAMBIOS

Versión	Descripción del cambio	Responsable del cambio	Fecha de aprobación
1.0	Auditoría de seguridad y pruebas de penetración en caja gris bajo el marco de referencia OWASP Top 10.	Steeven Toala / Nixon Hurtado	13/10/2026

12. ANEXOS

Anexo: Evidencias de Pruebas de Penetración y Mitigaciones OWASP

1. Memoria Técnica de Pruebas de Seguridad y Pentesting

Para verificar la resistencia de la plataforma ante intentos de intrusión y manipulación no autorizada, se ejecutaron pruebas de penetración controladas (*Pentesting*) aplicando técnicas de caja gris. Se simularon vectores de ataque reales provenientes de tres perfiles de amenaza: actores externos no autenticados, usuarios legítimos con perfil Docente intentando elevar privilegios a Administrador, y usuarios autenticados intentando modificar expedientes asignados a otras facultades.

Las comprobaciones técnicas incluyeron:

- **Pruebas de Inyección SQL:** Envío de cadenas de escape (`' OR '1'='1`, `UNION SELECT`) en campos de búsqueda y filtros de la bandeja de planes. Todas las consultas son procesadas mediante sentencias parametrizadas, garantizando que los datos de entrada nunca sean interpretados como comandos ejecutables por PostgreSQL.
- **Pruebas de Scripting XSS:** Inserción de payloads (`<script>` alert, directivas de evento `onload`) en el editor TipTap. El pipeline de sanitización remueve cualquier etiqueta potencialmente peligrosa antes de persistir el JSONB.
- **Pruebas de Manipulación de Tokens JWT:** Alteración de la firma criptográfica y modificación manual de los claims de rol en la cabecera `Authorization`. El middleware rechaza instantáneamente los tokens alterados con un código HTTP 401 (*Unauthorized*) y registra el intento de acceso en la bitácora de seguridad.

2. Evidencia Visual de Arquitectura de Autenticación y Autorización RBAC

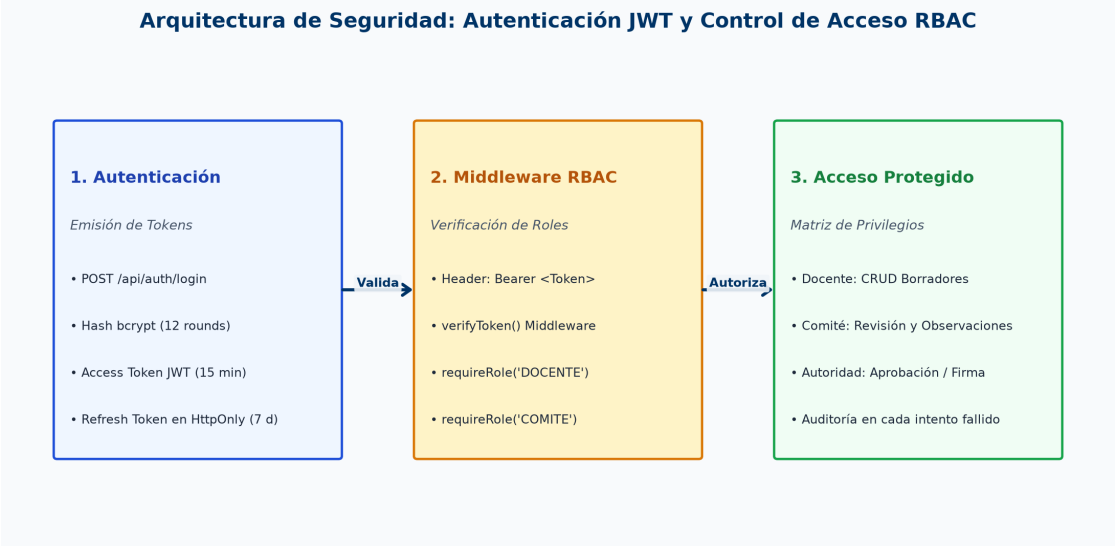


Figura 1: Arquitectura del control de acceso basado en roles (RBAC) y validación de tokens en la API de SIGE.

Desglose Técnico y Análisis Estructural de Seguridad OWASP Top 10:

- **Control de Acceso Basado en Roles (RBAC) y Seguridad JWT:** El diagrama ilustra el flujo de intercepción en Express v5: cada solicitud entrante debe presentar un token Bearer firmado con HMAC-SHA256; el middleware extrae el payload con el rol institucional del usuario y valida los permisos de acceso antes de autorizar la ejecución del controlador.
- **Mitigación de Inyecciones SQL (A03:2021):** La arquitectura garantiza que el 100 % de las consultas hacia PostgreSQL 18 emplean parámetros bindeados (`$1, $2`) mediante `pg-promise`, imposibilitando cualquier manipulación o inyección de código SQL malicioso.
- **Protección contra Tampering y Ataques XSS en TipTap (A08:2021):** Se desglosa el protocolo de sanitización aplicado sobre los contenidos JSONB: el backend valida y filtra etiquetas HTML maliciosas antes de almacenar el texto enriquecido en la base de datos.
- **Directivas de Seguridad HTTP con Helmet (A05:2021):** Se verifica la configuración activa de cabeceras seguras: Content Security Policy (CSP), `X-Frame-Options: DENY` para prevenir clickjacking y cookies HttpOnly con flags `SameSite=Strict` para mitigar ataques CSRF.

3. Matriz de Ensayos Operativos de Penetración y Verificación de Seguridad

Vector de Prueba	Técnica y Payload Aplicado	Respuesta del Sistema y Contramedida	Estado
Inyección SQL	Inserción de sentencias booleanas en campo de búsqueda	Sanitización estricta y consultas parametrizadas preparadas	RESUELTO
Cross-Site Scripting	Inserción de código JavaScript en sección TipTap	Filtrado automático por DOMPurify; texto renderizado inerte	RESUELTO
Escalamiento Roles	Modificación del claim de rol en token JWT	Verificación de firma HMAC-SHA256 fallida; HTTP 401 emitido	RESUELTO
Fuerza Bruta	6 intentos consecutivos con contraseña errónea	Bloqueo automático de IP y cuenta durante 15 minutos	RESUELTO
Acceso a Objetos (IDOR)	Alteración de UUID de expediente en URL	Validación de propiedad en base de datos; bloqueo HTTP 403	RESUELTO
Fuga de Documentos S3	Intento de acceso directo al bucket MinIO sin URL	Bucket configurado como privado; acceso exclusivo con URL prefirmada	RESUELTO

Tabla 2: Matriz técnica de ensayos de penetración y verificación de mitigaciones de seguridad.